Plano de Respostas aos Riscos

Projeto: Smart Tennis Arena (Projeto 5 - Grupo 5 LMPP / CCOMP6)

Data: 08/11/2026

Versão: 1.0

1. Introdução

Este documento detalha as estratégias e ações específicas planejadas para lidar com os riscos e vulnerabilidades identificados pela ferramenta Aikido Security (varredura SAST, SCA e IaC na branch main do repositório Projeto-Smart-Tennis (fork do projeto original no GitHub) no projeto Smart Tennis Arena (Backend Node.js 22 + Express 4.21.2 + TypeScript + MySQL 8.0 + Docker, Mobile Expo ~57.0.22 + React Native 0.86.3 e Firmware Arduino Uno R3). O objetivo é aumentar as oportunidades (riscos positivos, como automação via Aikido AutoFix) e reduzir ou eliminar as ameaças (riscos negativos de segurança da aplicação, containers e dependências) aos objetivos do projeto.

2. Tabela de Respostas aos Riscos

Esta tabela serve como o núcleo do plano, detalhando a resposta para cada risco priorizado.

ID do Risco	Descrição do Risco	Nível do Risco (Prioridade)	Estratégia de Resposta	Ações Específicas Planejadas (Apontadas pela Aikido Security)	Responsável pela Ação	Prazo para Implementação	Status
SAST-001	Express is not emitting security headers: O servidor Express em src/backend/src/server.ts (linha const app = express();) não utiliza o middleware Helmet e opera com cors({ origin: '*' }), deixando a REST API (porta 3001) exposta a ataques web como XSS, Clickjacking e falta de HSTS/CSP (Aikido Score: 85 / High Risk).	**Alto**	**Mitigar**	1. Instalar o pacote helmet e @types/helmet em src/backend/package.json. 2. Importar e registrar app.use(helmet()) antes das rotas (/api/auth, /api/users, /api/audit-logs, /api/health) em src/backend/src/server.ts. 3. Restringir a origem do middleware CORS para o domínio/porta do app Expo (http://localhost:8081 e URL de produção). Tempo estimado pelo Aikido: 45 min.	Pedro Schaurich Maia	06/11/2026	Em Andamento

ID do Risco	Descrição do Risco	Nível do Risco (Prioridade)	Estratégia de Resposta	Ações Específicas Planejadas (Apontadas pela Aikido Security)	Responsável pela Ação	Prazo para Implementação	Status
SCA-001	Vulnerabilidades na biblioteca zod (v3.25.76) em src/mobile/package-lock.json: Afetada por 2 CVEs (Aikido Score: 69 / Medium Risk) — AIKIDO-2026-10707 (Prototype Pollution via chave __proto__ em schemas com .catchall()) e AIKIDO-2026-10706 (validador Base64 ignora espaços em branco ASCII, aceitando payloads não estritos).	**Médio**	**Mitigar**	1. Atualizar a dependência zod em src/mobile/package-lock.json da versão 3.25.76 para a versão corrigida 4.4.0. 2. Caso haja breaking changes com o ecossistema Expo ~57.0.22, aplicar o patch seguro da Aikido Library mantendo a versão atual. 3. Executar a suíte de 11 testes automatizados (src/packages/shared/test/shared.test.ts) para validar contratos. Tempo estimado: 1h.	Lucas Oliveira	06/11/2026	Não Iniciado
IAC-001	Docker container runs as default root user: O arquivo	**Médio**	**Prevenir (Evitar)**	1. Alterar src/backend/Dockerfile ajustando permissões de	Matheus Rossaneze	06/11/2026	Em Andamento

ID do Risco	Descrição do Risco	Nível do Risco (Prioridade)	Estratégia de Resposta	Ações Específicas Planejadas (Apontadas pela Aikido Security)	Responsável pela Ação	Prazo para Implementação	Status
	src/backend/Dockerfile (linhas 1 a 10, imagem base FROM node:22-alpine) executa o processo CMD ["node", "dist/server.js"] sem definir um usuário não-privilegiado, permitindo escalonamento de privilégios para root no host Docker em caso de comprometimento da API (Aikido Score: 65 / Medium Risk).			diretório (RUN chown -R node:node /app) após o npm run build. 2. Adicionar a diretiva USER node antes do EXPOSE 3001 e CMD ["node", "dist/server.js"] para eliminar a execução como root. 3. Reconstruir e validar a imagem via docker compose up -d. Tempo estimado: 1h.			
SCA-002	Attacker can trigger DoS-attack (raw-body v2.5.2): Dependência	**Baixo**	**Mitigar**	1. Atualizar o pacote raw-body em src/backend/package-lock.json da versão 2.5.2 para a	Phelipe Antonio	06/11/2026	Não Iniciado

ID do Risco	Descrição do Risco	Nível do Risco (Prioridade)	Estratégia de Resposta	Ações Específicas Planejadas (Apontadas pela Aikido Security)	Responsável pela Ação	Prazo para Implementação	Status
	transitiva do Express/body-parser em src/backend/package-lock.json (AIKIDO-2026-274460, Aikido Score: 37 / Low Risk). Se a opção limit receber um valor inválido ou NaN, a verificação de limite de bytes é ignorada e o stream inteiro é armazenado em buffer, podendo exaurir memória/CPU.			versão 4.0.0 (que rejeita limites inválidos com TypeError). 2. Definir explicitamente um limite seguro de payload em src/backend/src/server.ts utilizando app.use(express.json({ limit: '100kb' })). Tempo estimado: 1h.			
SCA-003	Abuse of JavaScript's prototype API possible (Prototype	**Baixo**	**Aceitar (Ativo)**	1. Confirmar via Reachability Analysis do Aikido que o yargs é utilizado apenas em tempo de build/CLI pelo	Pedro Schaurich Maia	Contínuo	Em Andamento

ID do Risco	Descrição do Risco	Nível do Risco (Prioridade)	Estratégia de Resposta	Ações Específicas Planejadas (Apontadas pela Aikido Security)	Responsável pela Ação	Prazo para Implementação	Status
	Pollution em yargs v17.7.2): Presente em src/mobile/package-lock.json (AIKIDO-2026-922647, Aikido Score: 24 / Low Risk). A função mergeDeep em apply-extends mescla objetos recursivamente sem ignorar a chave __proto__, permitindo poluição de protótipo em configurações.			Metro Bundler/Expo, sem exposição a payloads externos em produção. 2. Agendar a atualização do pacote yargs para a versão 18.1.0 via overrides no package.json durante a janela de manutenção da Sprint. Tempo estimado: 1h.			
OPP-001	A utilização do recurso Aikido AutoFix e integração contínua de segurança na	**Alto**	**Explorar (Oportunidade)**	1. Utilizar o recurso AutoFix do Aikido Security para gerar Pull Requests automatizados de atualização de dependências (zod,	Pedro Schaurich Maia	06/11/2026	Em Andamento

ID do Risco	Descrição do Risco	Nível do Risco (Prioridade)	Estratégia de Resposta	Ações Específicas Planejadas (Apontadas pela Aikido Security)	Responsável pela Ação	Prazo para Implementação	Status
	branch main pode acelerar a remediação das 5 vulnerabilidades em até 70% e comprovar maturidade DevSecOps na avaliação final da FECAP.			raw-body, yargs) e configuração de segurança (Helmet e Dockerfile). 2. Executar novo scan no Aikido Security após o merge para registrar score 100% limpo na documentação da Entrega 2.			

3. Detalhamento das Estratégias de Resposta

3.1. Estratégias para Ameaças (Riscos Negativos)

- **Prevenir (Evitar):** Mudar o plano do projeto para eliminar a ameaça por completo. Significa não realizar a atividade que contém o risco.
    - *Exemplo:* Configurar a diretiva USER node no src/backend/Dockerfile para eliminar por completo a execução do container da API como superusuário root, ou isolar a comunicação com o Arduino Uno R3 exclusivamente via cabo USB Serial físico (sem Wi-Fi/Bluetooth exposto).
- **Transferir:** Repassar o impacto negativo do risco (e a responsabilidade pela resposta) para um terceiro. Não elimina o risco, apenas o transfere.
    - *Exemplo:* Hospedar o banco de dados MySQL e o container do Backend em provedores PaaS/Cloud DB com proteção DDoS, TLS/SSL nativo via DATABASE_URL e SLA de disponibilidade.
- **Mitigar:** Reduzir a probabilidade de ocorrência do risco e/ou seu impacto no projeto a um nível aceitável.
    - *Exemplo:* Adicionar o middleware Helmet e limitar o tamanho do JSON em src/backend/src/server.ts, além de atualizar os pacotes zod (v4.4.0) e raw-body (v4.0.0) apontados pelo Aikido Security.
- **Aceitar:** Nenhuma ação proativa é tomada para alterar o plano do projeto.
    - **Aceitação Ativa:** Manter monitoramento de alcançabilidade (Reachability Analysis no Aikido) e reservar ~1 hora da sprint para atualizar dependências transitivas de CLI como yargs (v18.1.0) em janela controlada.
    - **Aceitação Passiva:** Não realizar alterações imediatas em sub dependências exclusivas de desenvolvimento local que não afetam o binário de produção e lidar com avisos caso o escopo mude (geralmente para riscos de baixa prioridade).

3.2. Estratégias para Oportunidades (Riscos Positivos)

- **Explorar:** Tomar ações para garantir que a oportunidade se concretize.
    - *Exemplo:* Acionar imediatamente o Aikido AutoFix conectado ao GitHub (Projeto-Smart-Tennis) para gerar patches automáticos das 5 vulnerabilidades em menos de 4 horas e 45 minutos totais.
- **Melhorar (ou Realçar):** Aumentar a probabilidade de ocorrência da oportunidade e/ou seu impacto positivo.

    - *Exemplo:* Capacitar os integrantes do Grupo 5 na interpretação de SAST, SCA e IaC do Aikido Security e ampliar os testes unitários em src/packages/shared/test/shared.test.ts.

- **Compartilhar:** Alocar a responsabilidade da oportunidade a um terceiro que esteja mais apto a aproveitá-la em benefício do projeto.
    - *Exemplo:* Integrar a governança do código com os professores orientadores da FECAP e utilizar a Aikido Library para aplicar patches de segurança sem introduzir breaking changes no projeto.
- **Aceitar:** Não buscar ativamente a oportunidade, mas aproveitá-la se ela acontecer.
    - *Exemplo:* Aproveitar melhorias automáticas de segurança nas imagens oficiais node:22-alpine e mysql:8.0 do Docker Hub durante os builds regulares do projeto.

4. Monitoramento e Revisão

Este plano será revisado semanalmente (a cada novo scan na branch main do Aikido Security durante o período grátis) nas reuniões de status do projeto Smart Tennis Arena. O campo **"Status"** será atualizado para refletir o progresso das ações planejadas (Ex: Não Iniciado, Em Andamento, Concluído, Cancelado).